

Digital Sovereignty In Practice

Roger Halbheer, Chief Security Advisor

A customer-facing framework for CISOs regarding sovereignty with scenarios mapped to the EU Cloud Sovereignty Framework and Microsoft-centric controls.

This document was written with the help of Copilot.

Executive Summary

Digital sovereignty is the ability to keep control of your digital services - your data, access, encryption keys, operations, and continuity - so you can meet local obligations and keep running even when geopolitics, legal demands, or provider dependencies get uncomfortable. It is not “where the datacenter is”; it is who can do what, under which laws, and what happens in an exception.

BSI C3A: Digital sovereignty describes the abilities and opportunities of individuals and institutions to perform their role(s) in the digital world independently, self-determinedly (autonomous) and securely.

Customers care about sovereignty right now because three pressures are rising at the same time:

- *regulation* (residency, auditability, NIS2/DORA-style oversight),
- *trust and transparency* (who can access content during support and incidents), and
- *geopolitical continuity risk* (sanctions, export controls, or forced service suspension).

The result: CISOs are being asked to turn a fuzzy political term into concrete requirements that can be engineered and evidenced.

Sovereignty fails when it becomes “theatre”: treating every workload as exceptional, or focusing on data location alone while ignoring key custody and operational access - adding cost and complexity without reducing real risk.

In October 2025, the European Commission published the Cloud Sovereignty Framework (v 1.2.1) which was developed to provide a standardized approach for assessing the sovereignty of cloud services procured by EU institutions. It aims to ensure that these services align with European values and legal standards, thereby enhancing the EU's digital autonomy and security.

This paper tries to make sovereignty actionable by mapping customer requirements to this framework by focusing on six scenarios that show up repeatedly in real procurement and risk discussions.

The six scenarios this paper focuses on are:

- S1 - Sanctions / service suspension / geopolitical “kill switch”
- S2 - Extraterritorial laws / legal conflict / compelled actions
- S3 - In country/in region data residency & processing (incl. support data)
- S4 - Privileged access & operational transparency (support access)
- S5 - Key sovereignty (“provider can’t decrypt”) & confidential processing
- S6 - Supply chain + sustainability resilience (long-term autonomy)

Each scenario includes the underlying sovereignty objective(s) from the EU framework, practical mitigations (people/process/technology/legal), and the tradeoffs to avoid over-engineering.

Why this matters now (and what “sovereignty” usually means)

Outside the US, “sovereignty” is rarely a single requirement. Customers typically mean some combination of:

- *Control over data and AI* (where data is stored/processed; who can access it; key custody; auditability).
- *Jurisdictional resilience* (exposure to non-local laws with cross-border reach; enforceability of local rights).
- *Strategic continuity* (the “kill switch” fear: could a provider be forced to suspend services due to sanctions/export controls or geopolitical pressure).

The European Commission’s Cloud Sovereignty Framework makes this explicit by defining eight sovereignty objectives (SOV-1..SOV-8) and graded assurance levels (SEAL-0..SEAL-4), rather than treating sovereignty as binary. This framework shall be used as a baseline throughout the document.

Recommendation: don’t buy a “sovereign cloud” as a slogan. Classify workloads, decide which sovereignty objectives actually matter for each, and then apply the smallest set of controls that meet them (residency where needed, strict operational access transparency, and customer-controlled encryption keys). Reserve fully isolated or customer-operated environments for the small set of must-run services where continuity outweighs cost, usability, and innovation speed.

Sovereignty taxonomy - aligned to the EU Cloud Sovereignty Framework

The EU Cloud Sovereignty Framework defines the following objectives and the factors that contribute to each, including legal exposure, operational oversight, key control, auditability, supply-chain provenance, and sustainability.

- *SOV-1 (Strategic Sovereignty)*: Are services anchored in the EU ecosystem - and can operations continue if asked to cease/suspend service or if support is disrupted?
- *SOV-2 (Legal & Jurisdictional Sovereignty)*: Which laws can compel actions, and to what extent is the service insulated from external legal claims?
- *SOV-3 (Data & AI Sovereignty)*: Where is data processed, who has effective control over cryptographic access, and how is AI usage/access audited?
- *SOV-4 (Operational Sovereignty)*: Can EU actors operate/support/evolve the service without foreign dependency; how portable is it?
- *SOV-5 (Supply Chain Sovereignty)*: What non-EU dependencies exist in hardware, firmware, code, and delivery chain; what transparency/audit rights exist?
- *SOV-6 (Technology Sovereignty)*: Is the stack open/interoperable/auditable; can customers avoid irreversible lock-in and evolve independently?
- *SOV-7 (Security & Compliance Sovereignty)*: Can security operations and compliance be evidenced under EU-aligned control expectations (e.g., NIS2/DORA)?
- *SOV-8 (Environmental Sustainability)*: Does long-term autonomy/resilience depend on energy/resource constraints, and is sustainability measurable?

SEAL levels (assurance): The Cloud Sovereignty Framework uses graded Sovereignty Assurance Levels (SEAL-0..SEAL-4) to express how strongly a service meets an objective - moving from no specific sovereignty assurances to independently evidenced, highest-rigor controls:

- *SEAL-0*: Not assessed / no explicit: Cloud Sovereignty Framework sovereignty assurances claimed.
- *SEAL-1*: Baseline controls and statements of conformity; limited evidence.
- *SEAL-2*: Defined controls implemented and documented; more structured evidence.
- *SEAL-3*: High assurance-controls are comprehensive and consistently operated; strong evidence and auditability.
- *SEAL-4*: Highest assurance-most stringent requirements with robust, independent verification and continuous assurance signals where applicable.

In practice, the framework can be applied globally by substituting “European Union” with any non-US jurisdiction.

Implementation consequences

In customer discussions, sovereignty is often framed as a binary choice. It is critical to move away from this mindset and treat sovereignty as part of standard risk management. The appropriate approach is to assess requirements through a structured matrix that reflects different needs across services, rather than applying a one-size-fits-all answer.

In practice, for each service or workload, you typically end up with a matrix like this:

Assurance Level needed for service x:

How the table shall be read: The service x needs SEAL-0 for SOV-1, SEAL-2 for SOV-2, SEAL-1 for SOV-3 etc.

	SEAL-0	SEAL-1	SEAL-2	SEAL-3	SEAL-4
<i>SOV-1 (Strategic Sovereignty)</i>	x				
<i>SOV-2 (Legal & Jurisdictional Sovereignty)</i>	x	x	x		
<i>SOV-3 (Data & AI Sovereignty)</i>	x	x			
<i>SOV-4 (Operational Sovereignty)</i>	x				
<i>SOV-5 (Supply Chain Sovereignty)</i>	x	x	x	x	
<i>SOV-6 (Technology Sovereignty)</i>	x				
<i>SOV-7 (Security & Compliance Sovereignty)</i>	x	x	x		
<i>SOV-8 (Environmental Sustainability)</i>	x	x	x	x	x

These choices affect architecture, operations, and cost - and should be weighed accordingly.

Risk Assessment

Risk assessment is already an established practice in many organizations. In the following scenarios, this paper defines risk as the combination of two factors:

- Likelihood: Standard classification can be: Unlikely, Possible, Likely, Highly Likely and Almost Certain. The definition might be different from customer to customer.

- Impact: Standard classification can be: Insignificant, Minor, Moderate, Major or Critical. The definition might be different from customer to customer.

The likelihood and impact ratings will vary by customer depending on the criticality of the affected services. Combining these factors provides a clear view of overall risk and enables prioritization across scenarios for each workload. Lower-risk scenarios should not be ignored, but this approach ensures focus is directed appropriately. By integrating sovereignty scenarios into the broader risk register, the discussion shifts from emotion or external pressure to a structured, consistent, and commonly agreed risk-based approach aligned with other business risks.

Key Scenarios

Below are six scenarios that cover the majority of customer “sovereignty” conversations, mapped to the Cloud Sovereignty Framework objectives:

Legend: ● Primary | ○ Secondary

Scenario	SOV-1 (Strategic Sovereignty)	SOV-2 (Legal & Jurisdictional Sovereignty)	SOV-3 (Data & AI Sovereignty)	SOV-4 (Operational Sovereignty)	SOV-5 (Supply Chain Sovereignty)	SOV-6 (Technology Sovereignty)	SOV-7 (Security & Compliance Sovereignty)	SOV-8 (Environmental Sustainability)
S1 - Sanctions / service suspension / geopolitical “kill switch”	●	○		●	○	○	○	
S2 - Extraterritorial laws / legal conflict / compelled actions	○	●	○	○			○	
S3 - In country/in region data residency & processing (incl. support data)		○	●				○	
S4 - Privileged access & operational transparency (support access)			○	●			●	
S5 - Key sovereignty (“provider can’t decrypt”) & confidential processing		○	●	○		●	○	
S6 - Supply chain + sustainability resilience (long-term autonomy)	○			○	●	○	○	●

Scenario S1 - Sanctions / service suspension / geopolitical “kill switch”

Mapped

Primary

- SOV-1 (Strategic Sovereignty)
- SOV-4 (Operational Sovereignty)

Secondary

- SOV-2 (Legal & Jurisdictional Sovereignty)
- SOV-5 (Supply Chain Sovereignty)
- SOV-6 (Technology Sovereignty)
- SOV-7 (Security & Compliance Sovereignty)

Description

Customers fear a foreign administration could force a provider via sanctions/export controls or restrictions on service provision to suspend certain or all digital services. The Cloud Sovereignty Framework explicitly calls out the need to sustain operations against requests to cease/suspend a service or disrupted vendor support.

Sanctions practice can include restrictions on providing “cloud-based services” and SaaS categories for certain destinations, demonstrating that service delivery can be targeted as a policy instrument.

Risk

- Likelihood: **Unlikely to Possible**, with higher perceived concern for public sector and critical operators; service-restriction instruments exist.
- Impact: **Critical** for must-run services (public services, critical infrastructure) because this is an availability and continuity failure mode.

Mitigating Actions

- People: Assign a cross-functional owner (CISO + Legal + Risk) for “geopolitical/service-continuity risk” and maintain board visibility for critical services.
- Process: Implement and test exit plans (data export, identity, app portability, runbooks) and define a “minimum viable operations” baseline for crisis continuity.
- Technology (Microsoft examples):
 - For most workloads: use Sovereign Public Cloud controls and architect for portability (reduce single-point dependency while retaining hyperscale benefits).
 - For “must-run” workloads: use Sovereign Private Cloud (customer-operated) combining Azure Local + Microsoft 365 Local.
 - Edge / offline transition: Azure Stack Edge^[1] and Azure Data Box^[2] enable staged or emergency data movement and local processing when cloud connectivity is unavailable or intentionally severed, supporting transition into disconnected sovereign operations.
- National Partner Clouds (where available): Local partner-operated sovereign implementations designed to meet country-specific frameworks (availability and scope vary by geography).

Downside / tradeoff

Private/local sovereign environments reduce hyperscale cloud benefits (cost efficiency, agility, innovation speed) - a trade-off Microsoft’s sovereignty guidance acknowledges.

Sovereign Private Clouds typically cost more, reduce functionality, and add a significant talent burden: scarce platform/identity/security skills, plus patching, backup/DR, 24/7 coverage, and disciplined runbooks to stay reliable under stress.

Scenario S2 - Extraterritorial laws / legal conflict / compelled actions

Mapped

Primary

- SOV-2 (Legal & Jurisdictional Sovereignty)

Secondary

- SOV-1 (Strategic Sovereignty)
- SOV-3 (Data & AI Sovereignty)
- SOV-4 (Operational Sovereignty)
- SOV-7 (Security & Compliance Sovereignty)

Description

Customers worry that non-local laws with cross-border reach can compel actions or create legal uncertainty even if services run within the local jurisdiction - exactly what *SOV-2 (Legal & Jurisdictional Sovereignty)* evaluates.

In the case of the European Union, the EU's Blocking Statute^[^3] exists to protect EU operators from the extraterritorial application of certain third-country laws and sets mechanisms including non-recognition of certain foreign judgments, damage recovery, and restrictions on compliance (with a derogation mechanism).

Risk

- Likelihood: **Unlikely to Possible** depending on sector, footprint, and exposure; EU guidance emphasizes mapping transfers and assessing protections.
- Impact: **Major to Critical** for public sector and regulated industries due to enforceability and trust consequences.

Mitigating Actions

- People/Process: Maintain "know your transfers" discipline and a documented approach to risk assessment and supplementary measures. The International Association of Privacy Professionals (IAPP) provides published guidance on performing Transfer Impact Assessments^[^4].
- Technology: Minimize cross-border processing and strengthen cryptographic and operational controls (ties directly to *S3 - In country/in region data residency & processing (incl. support data)*, *S4 - Privileged access & operational transparency (support access)*, *S5 - Key sovereignty ("provider can't decrypt") & confidential processing*).
- Legal: Understand Blocking Statute obligations and derogation path; treat this as a governance tool - not a guaranteed technical control.

Downside / tradeoff

Legal and process overhead is ongoing: maintaining transfer maps, running Transfer Impact Assessments, updating contracts and supplementary measures, and managing Blocking Statute obligations/derogations can add continuous governance work. In practice, this often lengthens procurement cycles and slows change management, because legal review and evidence collection must keep pace with new services, features, vendors, and cross-border support scenarios - especially in regulated sectors.

Scenario S3 - In country/in region data residency & processing (incl. support data)

Mapped

Primary

- SOV-3 (Data & AI Sovereignty)

Secondary

- SOV-2 (Legal & Jurisdictional Sovereignty)
- SOV-7 (Security & Compliance Sovereignty)

Description

Customers - driven by regulatory obligations and the need to simplify initial and ongoing risk assessments - require that their data and all related processing remain within a defined country or region (for example, the EU). This end-to-end data residency requirement covers not only primary storage, but also compute workloads, backups, and operational data generated during service delivery, including logs, diagnostics, support artifacts, and engineering workflows. It is most common in regulated industries and public-sector procurements, where residency applies across the full-service lifecycle, including incident response and vendor support. Such commitments are only credible if organizations can clearly demonstrate where data is processed and how exceptions (for example, break/fix support or cross-border escalation) are prevented, formally approved, or governed with full transparency.

Risk

- Likelihood: **Unlikely to Possible** depending on service selection and configuration; some Azure services may require customer action for certain commitments.
- Impact: **Major** due to regulatory exposure and reputational impact.

Mitigating Actions

- People: Assign data residency accountability; require residency verification in architecture and procurement.
- Process: Maintain data flow maps and evidence packs for audits and tenders.
- Technology (Microsoft examples):
 - Use EU Data Boundary^[5] baseline for eligible services, where applicable.
 - Use Advanced Data Residency^[6] (ADR) where country-level commitments are required and eligible.

Downside / tradeoff

EU Data Boundary configurations and (where needed) Advanced Data Residency can add cost and delivery friction: eligibility checks and tenant migrations, tighter constraints on where workloads and support processes may run, and additional discipline to ensure new features, integrations, and incident workflows stay within the agreed boundary. The required countermeasures (data-flow mapping, evidence packs, and residency verification in architecture and procurement) create ongoing governance overhead. From a resilience perspective, strict “stay-in-region” designs can also limit failover, capacity balancing, and service choice, reducing architectural flexibility and potentially increasing outage impact. As a result, overly rigid residency

decisions may delay adoption or constrain recovery options without materially reducing risk for non-critical workloads.

Scenario S4 - Privileged access & operational transparency (support access)

Mapped

Primary

- SOV-4 (Operational Sovereignty)
- SOV-7 (Security & Compliance Sovereignty)

Secondary

- SOV-3 (Data & AI Sovereignty)

Description

Customers want assurance that no unauthorized party across the supply chain—including cloud operators, subcontractors, managed service providers, or support personnel—can access customer content without explicit customer approval, and that any permitted access is strictly time-bound, least-privilege, and fully auditable. This requires a clear separation between routine service operations and exceptional break/fix scenarios, with transparent logging of who accessed what, when, why, and under whose authorization, enabling customers to demonstrate effective control to regulators and internal audit.

Risk

- Likelihood: **Likely**; support scenarios occur and some require content-access workflows.
- Impact: **Major** due to content exposure, audit gaps, and compliance issues.

Mitigating Actions

- People: Minimize privileged roles; define 24/7 approver coverage if Lockbox is enabled.
- Process: Approval workflows + periodic review of access logs and requests.
- Technology (Microsoft examples):
 - Microsoft Purview Customer Lockbox^[7] requires explicit customer approval before Microsoft can access content for service operations in supported services.
 - Microsoft Data Guardian^[8] (Sovereign Public Cloud capability) adds EU-resident approval/monitoring for remote access and logs sessions in a tamper-evident ledger.

Downside / tradeoff

Support can slow if the Mitigating Actions are not operationalized: Customer Lockbox/Data Guardian introduce an explicit approval step, and if 24/7 approver coverage, escalation paths, and runbooks are not in place, break/fix activities can queue while teams wait for authorization. Minimizing privileged roles and performing periodic review of access requests/logs improves control and auditability, but adds process overhead and coordination, particularly during incidents when speed matters.

Scenario S5 - Key sovereignty (“provider can’t decrypt”) & confidential processing

Mapped

Primary

- SOV-3 (Data & AI Sovereignty)
- SOV-6 (Technology Sovereignty)

Secondary

- SOV-2 (Legal & Jurisdictional Sovereignty)
- SOV-4 (Operational Sovereignty)
- SOV-7 (Security & Compliance Sovereignty)

Description

Customers ask for key sovereignty because control of the encryption keys is control of the data: if the provider does not hold the keys, it cannot technically decrypt customer content - even if its platform, administrators, or supply chain are compromised - and it is materially harder to comply with compelled access requests, since the provider cannot disclose plaintext it cannot produce.

Risk

- Likelihood: **Likely** because stronger key custody increases operational complexity and the chance of key lifecycle mistakes.
- Impact: **Major to Critical** because key loss can cause data loss and misconfiguration can cause exposure.

Mitigating Actions

- People: Segregation of duties (key admins ≠ data admins).
- Process: Rotation, escrow/break-glass, recovery testing.
- Technology (Microsoft examples):
 - Microsoft Customer-Managed Keys^[9] (CMK): customer controls the encryption keys, so the provider can’t decrypt customer data without customer authorization.
 - Double Key Encryption^[10] (DKE): data is protected by two keys (provider + customer), so the provider can’t decrypt it without customer participation.
 - External Key Management^[11] (Sovereign Public Cloud): customer-held keys outside the provider, so the provider can’t decrypt customer data without customer authorization.
 - Azure Confidential Computing^[12]: protects data in use by running workloads in hardware-isolated trusted environments, reducing exposure even to privileged infrastructure access. Confidential Computing limits platform access technically, but does not eliminate provider dependency on the control plane; customers seeking full hardware and operations exclusion must move to customer-operated sovereign platforms.

Downside / tradeoff

Strong key sovereignty (CMK/DKE/EKM) adds a hard operational dependency between the cloud service and your external key environment (often on-prem), so outages or misconfiguration in key operations can directly impact availability.

It can also reduce cloud-native features that require server-side content processing, e.g., limited web viewing for DKE-protected content and constraints on capabilities like AI usage, search, malware scanning, and some DLP-style workflows depending on configuration.

Scenario S6 - Supply chain + sustainability resilience (long-term autonomy)

Mapped

Primary

- SOV-5 (Supply Chain Sovereignty)
- SOV-8 (Environmental Sustainability)

Secondary

- SOV-1 (Strategic Sovereignty)
- SOV-4 (Operational Sovereignty)
- SOV-6 (Technology Sovereignty)
- SOV-7 (Security & Compliance Sovereignty)

Description

The Cloud Sovereignty Framework evaluates supply-chain sovereignty through the origin and transparency of critical components, and sustainability through long-term resilience to energy and resource constraints. In practice, the Mitigating Actions (supplier mapping, contractual transparency, and substitution/portability plans) improve visibility and contingency options, but the “twist” is market reality: for key technologies (chips, firmware supply chains, hyperscale platforms, and energy-dense datacenter infrastructure) supplier diversity is limited, capacity is concentrated, and switching is slow and costly if even possible. This means many organizations can realistically reduce dependency risk only for a narrow set of truly critical workloads - while for the majority of services, resilience comes more from multi-region design, tested exit/portability runbooks, and procurement leverage than from achieving full regional sourcing end-to-end.

Risk

- Likelihood: **Likely**; supply and energy disruptions are recurring, although the effect varies by sector.
- Impact: **Major** for critical services dependent on specialized hardware or constrained locations.

Mitigating Actions

- People/Process: Map key suppliers; require contractual transparency; define substitution and exit plans; and keep procurement evidence aligned to *SOV-5 (Supply Chain Sovereignty)* and *SOV-8 (Environmental Sustainability)*.
- Technology: Use portability and resilience patterns (multi-region design, tested recovery, documented exit runbooks). Only for exceptional cases, consider local operating models to reduce dependence on specific external supply chains.

Downside / tradeoff

The Mitigating Actions can look tidy on paper but become costly “paperwork sovereignty” if applied broadly: deep supplier mapping and transparency demands slow procurement (and often meet vendor pushback), while exit/substitution plans are rarely realistic or exercised enough to be credible. Portability patterns help, but they still add engineering and operating cost - and in a concentrated market, switching is slow and uncertain. Local operating models can reduce specific dependencies, but typically reintroduce platform cost, staffing burden, and innovation drag; in practice, reserve the strictest measures for truly critical services and treat full supply-chain sovereignty as an aspiration, not a default baseline.

What makes sense (and what doesn't) - the evaluation

To recap the SEAL levels of the Cloud Sovereignty Framework:

- SEAL-0: Not assessed / no explicit Cloud Sovereignty Framework sovereignty assurances claimed.
- SEAL-1: Baseline controls and statements of conformity; limited evidence.
- SEAL-2: Defined controls implemented and documented; more structured evidence.
- SEAL-3: High assurance-controls are comprehensive and consistently operated; strong evidence and auditability.
- SEAL-4: Highest assurance-most stringent requirements with robust, independent verification and continuous assurance signals where applicable.

What usually makes sense for most customers (Tier 1–2 workloads):

- Treat sovereignty as an enterprise risk and manage it through standard risk management practices; it is not binary.
- Target SEAL-2/SEAL-3 outcomes for the sovereignty objectives that matter most (often *SOV-2 (Legal & Jurisdictional Sovereignty)*, *SOV-3 (Data & AI Sovereignty)*, *SOV-4 (Operational Sovereignty)*, *SOV-7 (Security & Compliance Sovereignty)*) rather than “full sovereignty everywhere,” consistent with the Cloud Sovereignty Framework’s graded approach.
- Use EU Data Boundary as baseline and Advanced Data Residency only where country-level commitments are necessary and eligible.
- Implement Customer Lockbox and/or Data Guardian when operational access transparency is required.
- Use Customer-Managed Keys broadly; reserve Double Key Encryption/External Key Management for a narrow, truly critical data class because key sovereignty increases operational complexity and impacts useability.

What only makes sense for exceptional cases (Tier 3 must-run)

- Use Sovereign Private Cloud (Azure Local + Microsoft 365 Local) when business continuity requirements outweigh the loss of some hyperscale cloud benefits and the loss of functionality - because *SOV-1 (Strategic Sovereignty)* explicitly includes resilience against service suspension and disrupted support.

What usually does *not* make sense (“sovereignty theatre”)

- “Residency-only” without operational access governance and key strategy fails to address *SOV-3 (Data & AI Sovereignty)* and *SOV-4 (Operational Sovereignty)* realities (control over access, keys, and operational oversight).
- Declaring every workload “must-run” and forcing private sovereignty everywhere increases cost and reduces innovation speed without proportional risk reduction - and many organizations underestimate the ongoing talent burden (scarce platform skills, 24/7 operations, patching and lifecycle management) needed to operate these environments safely and consistently.

Microsoft-centric control palette

Use this as a “menu” of controls in workshops and procurement. Each item includes what it does and where it typically fits.

Data residency & processing controls

- EU Data Boundary (Microsoft Cloud): Baseline commitment for eligible core services to store and process customer data (and pseudonymized personal data) within EU/EFTA, and to keep professional services data from support interactions in EU/EFTA for core services.
- Advanced Data Residency (ADR) for Microsoft 365: Optional add-on for country-level residency commitments (where eligible) and expanded service coverage beyond baseline commitments.

Operational access control & transparency

- Microsoft Purview Customer Lockbox: Ensures Microsoft can’t access your content for service operations without explicit customer approval (for supported services), improving transparency and control.
- Data Guardian (Sovereign Public Cloud): Adds EU-resident oversight of remote access by Microsoft personnel with approval + monitoring and logs sessions to a tamper-evident ledger, strengthening operational sovereignty.

Encryption & key sovereignty

- Customer-Managed Keys (CMK) with Azure Key Vault / Managed HSM: Lets customers control encryption keys for many Azure services (broad coverage varies by service) to support separation of duties and stronger key custody.
- Double Key Encryption (DKE) for Microsoft 365: For highly sensitive data, requires two keys to decrypt: one customer-controlled via a customer-operated DKE service and one in Azure; supports “provider can’t decrypt without customer participation” posture for protected content.
- External Key Management (Sovereign Public Cloud capability): Designed to enable customer control of encryption keys outside Microsoft’s cloud boundary (e.g., customer/trusted third-party HSMs) while still using Azure services - used where regulations demand stronger separation of key custody.

Confidential Computing (data in use protection)

- Azure Confidential Computing (Confidential VMs / containers; TEEs): Protects data in use by running computations inside hardware-based Trusted Execution Environments (TEEs), complementing encryption at rest/in transit and reducing the risk associated with operational access during processing.
- Secure key release via attestation (pattern): Enables releasing keys only after the workload proves (via attestation) it is executing inside a TEE, strengthening end-to-end control for sensitive workloads.
- Isolation model clarity: Azure achieves service and tenant isolation through a layered model combining hardware-rooted trust (Secure Host), hypervisor isolation, and Confidential Computing (TEEs). While not branded as a single component these layers jointly provide isolation from host administrators and infrastructure operators for eligible workloads.

Sovereign configuration & governance at scale

- Regulated Environment Management (REM): Provides a unified experience to configure, deploy, and monitor workloads for sovereign operations, working with policy-as-code guardrails and surfacing sovereignty signals (e.g., key usage/access oversight) for ongoing assurance.

Deployment models for maximum autonomy

- Sovereign Public Cloud (Microsoft Sovereign Cloud): Applies sovereign controls across European datacenter regions for services such as Azure/M365/Security/Power Platform, combining residency + operational oversight + encryption options without requiring migrations for EU workloads in-region (positioning).
- Sovereign Private Cloud (Azure Local + Microsoft 365 Local): Customer-operated environment for extraordinary sovereignty needs (air-gapped / disconnected / “must-run”), enabling operation with full infrastructure control where public cloud dependency is unacceptable.
- National Partner Clouds (where available): Partner-operated sovereign cloud offerings aligned to country-specific frameworks (availability and scope vary by country and segment).
- Azure Dedicated Host (clarifying note): Provides single-tenant host isolation for compliance or placement requirements, but does not change legal exposure, operational control, or service-suspension risk. As such, it is not a sovereignty control under *SOV-1 (Strategic Sovereignty)* or *[SOV-4 (Operational Sovereignty)]*, and should not be confused with Sovereign Private Cloud models.

Regulatory alignment (governance & assurance)

- NIS2 alignment: Use NIS2 risk-management and reporting requirements as a governance baseline across critical sectors (board accountability, supply chain security, incident reporting).
- DORA alignment (financial services): Use DORA for ICT risk management and ICT third-party risk management: contracts, auditability, resilience testing, and oversight for critical providers.